ANNEXE E

Plan de Continuité d'Activité (PCA)

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	15/07/2026	Consultant cybersécurité	Création du document
0.9	20/07/2026	DSI	Relecture technique
1.0	30/07/2026	Direction Générale	Validation officielle

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
DPO	Oui
Équipe informatique	Oui
Managers	Oui
Collaborateurs	Version adaptée

Confidentialité

Ce document est destiné exclusivement aux personnes autorisées par BioMarket. Il ne peut être diffusé sans l'accord de la Direction.

Table des matières

1. Présentation du Plan de Continuité d'Activité 3
2. Périmètre du Plan de Continuité d'Activité 6
3. Analyse d'Impact sur l'Activité (Business Impact Analysis – BIA) 10
4. Organisation de la gestion de crise 14
5. Stratégie de continuité et procédures opérationnelles 18
6. Tests, maintenance et amélioration du PCA 23
7. Annexes opérationnelles 26
8. Conclusion 30

1. Présentation du Plan de Continuité d'Activité

1.1 Objet

Le présent Plan de Continuité d'Activité (PCA) a pour objectif de garantir la continuité des activités essentielles de BioMarket en cas d'incident majeur affectant le système d'information ou les infrastructures de l'entreprise.
Il définit les mesures organisationnelles, techniques et humaines permettant de maintenir un niveau minimal de fonctionnement jusqu'au retour à une situation normale.
Le PCA constitue un élément essentiel du SMSI et s'appuie sur les résultats de l'analyse des risques réalisée selon la méthode EBIOS Risk Manager.

1.2 Objectifs

Les principaux objectifs du PCA sont les suivants :

- assurer la continuité des activités critiques ;
- limiter les interruptions de service ;
- protéger les données essentielles de l'entreprise ;
- réduire les impacts financiers, opérationnels et réglementaires ;
- garantir la sécurité des collaborateurs et des informations ;
- maintenir la confiance des clients, fournisseurs et partenaires.

1.3 Références

Le PCA est élaboré en conformité avec :

- ISO/IEC 27001 – Système de management de la sécurité de l'information ;
- ISO 22301 – Management de la continuité d'activité ;
- Règlement Général sur la Protection des Données (RGPD) ;
- Politique de Sécurité du Système d'Information (PSSI) de BioMarket ;
- Analyse des risques EBIOS Risk Manager (Annexe D).

1.4 Champ d'application

Le PCA couvre les activités critiques identifiées dans le périmètre du SMSI :

- siège social de BioMarket ;
- magasins connectés au système d'information ;
- infrastructures réseau ;
- serveurs et services d'authentification ;
- applications métiers ;
- plateforme e-commerce ;
- données clients, ressources humaines et commerciales ;
- mécanismes de sauvegarde et de restauration ;
- échanges avec les prestataires critiques.

La plateforme e-commerce constitue un composant du système d'information de BioMarket et est prise en compte dans le périmètre du PCA. Les exigences de continuité associées à la plateforme, aux données traitées et aux échanges avec le système d'information interne sont intégrées à l'analyse.
L'infrastructure PaaS et les composants internes administrés directement par Iron4Software restent hors du périmètre de responsabilité de BioMarket. Les engagements de continuité du prestataire sont pris en compte dans le suivi des services externalisés.

1.5 Objectifs de continuité

Conformément aux exigences du projet, les objectifs suivants ont été retenus :

Indicateur	Valeur cible
RTO (Recovery Time Objective)	4 heures
RPO (Recovery Point Objective)	12 heures

Le RTO correspond au délai maximal acceptable pour rétablir un service critique après un incident.
Le RPO correspond à la perte maximale de données acceptable, exprimée par l'intervalle entre le dernier point de récupération exploitable et la survenue de l'incident.
Ces objectifs constituent des cibles de continuité et devront être atteints grâce aux mécanismes de sauvegarde, de restauration et de reprise prévus dans le PCA.

1.6 Responsabilités

La mise en œuvre du PCA implique plusieurs acteurs.

Fonction	Responsabilités
Direction Générale	Déclenchement du PCA, décisions stratégiques
DSI	Coordination technique, évaluation des incidents, suivi des mesures de sécurité et restauration des services
Responsables métiers	Priorisation des activités et validation de la reprise
DPO	Conseil sur les incidents impliquant des données personnelles et suivi des obligations RGPD associées
Collaborateurs	Application des procédures prévues dans le PCA
Prestataires	Assistance technique conformément aux contrats

1.7 Conditions d'activation

Le PCA peut être déclenché notamment dans les situations suivantes :

- cyberattaque de type rançongiciel ;
- indisponibilité prolongée des serveurs critiques ;
- panne majeure du réseau informatique ;
- sinistre affectant les locaux (incendie, inondation) ;
- interruption prolongée des services essentiels ;

- compromission de données sensibles ;
- indisponibilité d'un fournisseur ou prestataire critique.

La décision d'activation du PCA est prise par la Direction Générale, sur proposition de la DSI, lorsque l'incident compromet ou risque de compromettre significativement la continuité des activités essentielles de BioMarket.

1.8 Cycle de vie du PCA

Le Plan de Continuité d'Activité est un document vivant. Il doit être :

- revu au minimum une fois par an ;
- mis à jour après chaque évolution importante du système d'information ou de l'organisation ;
- révisé à la suite d'un incident majeur ou d'un exercice de simulation ;
- validé par la Direction Générale.

Les résultats des exercices et des retours d'expérience sont pris en compte afin d'améliorer progressivement le dispositif de continuité.

2. Périmètre du Plan de Continuité d'Activité

2.1 Objectif

Le périmètre du Plan de Continuité d'Activité (PCA) définit les activités, les ressources et les services essentiels qui doivent être maintenus ou rétablis dans les délais fixés afin de limiter les conséquences d'un incident majeur sur le fonctionnement de BioMarket.

Ce périmètre est cohérent avec celui du SMSI et s'appuie sur les résultats de l'analyse des risques (Annexe D).

2.2 Activités couvertes

Les activités retenues dans le cadre du PCA sont celles dont l'interruption aurait un impact significatif sur le fonctionnement de BioMarket.

Activité	**Criticité**	**Justification**
Vente en magasin	Critique	Activité principale générant le chiffre d'affaires.
Gestion de la plateforme e-commerce	Critique	Permet la vente en ligne et constitue un canal commercial essentiel de BioMarket. Son indisponibilité peut entraîner une interruption des ventes en ligne et une perte de chiffre d'affaires.
Gestion des stocks	Critique	Garantit la disponibilité des produits et les approvisionnements.
Gestion des commandes fournisseurs	Élevée	Assure la continuité des livraisons et évite les ruptures de stock.
Gestion des données clients	Critique	Protège les informations personnelles et garantit le respect du RGPD.
Gestion des ressources humaines	Moyenne	Nécessaire au fonctionnement administratif de l'entreprise.
Services de messagerie et de communication	Élevée	Indispensables à la coordination interne et à la gestion de crise.

2.3 Ressources essentielles

Les activités critiques reposent sur plusieurs ressources indispensables au maintien des opérations.

2.3.1 Ressources humaines

- Direction Générale ;
- Direction des Systèmes d'Information (DSI) ;
- Délégué à la Protection des Données (DPO) ;
- Administrateurs systèmes et réseaux ;
- Responsables métiers.

2.3.2 Ressources techniques

- Active Directory ;
- Serveurs de fichiers et applicatifs ;
- Infrastructure réseau (switches, routeurs, pare-feu) ;
- Connexions VPN ;
- Plateforme e-commerce et interfaces associées ;
- Mécanismes de sauvegarde et de restauration à mettre en place ;
- Solutions de sécurité (antivirus, EDR, MFA).

2.3.3 Ressources informationnelles

- Données clients ;
- Données fournisseurs ;
- Données RH ;
- Données financières ;
- Documentation du SMSI.

2.4 Sites concernés

Le PCA couvre les principaux sites et infrastructures de BioMarket :

Site	**Rôle**
Siège social	Administration, hébergement des services centraux et pilotage de l'activité.
Magasins	Vente, gestion des stocks et relation client.
Infrastructure Cloud	Hébergement de certains services et solution de stockage/sauvegarde prévue

La plateforme e-commerce est prise en compte dans le périmètre du PCA en raison de son rôle dans les activités de vente en ligne et de sa dépendance vis-à-vis du prestataire Iron4Software.

Les échanges avec Iron4Software et les exigences de continuité associées au service e-commerce sont intégrés au PCA. En revanche, l'infrastructure PaaS et les composants internes administrés directement par Iron4Software restent hors du périmètre de

responsabilité de BioMarket. Les engagements de continuité du prestataire doivent être définis et suivis dans le cadre de la gestion des services externalisés.

2.5 Dépendances critiques

La continuité des activités dépend de plusieurs éléments clés.

Dépendance	**Impact en cas d'indisponibilité**
Active Directory	Impossible d'authentifier les utilisateurs et d'accéder aux ressources.
Réseau informatique	Perte des communications entre le siège et les magasins.
Serveurs applicatifs	Arrêt des applications métiers.
Mécanismes de sauvegarde et de restauration	Impossibilité de restaurer les données après un incident en l'absence de mécanismes opérationnels adaptés.
Fournisseurs	Perturbation de l'approvisionnement des magasins.
Prestataires informatiques	Retard dans les opérations de maintenance ou d'assistance.

2.6 Exigences de continuité

Afin d'assurer la résilience de BioMarket, les exigences suivantes ont été définies :

- maintenir les activités de vente en magasin et de vente en ligne en cas d'incident ;
- assurer la continuité de la gestion des stocks et des approvisionnements ;
- préserver la disponibilité et l'intégrité des données critiques grâce à une politique de sauvegarde et de restauration adaptée ;
- garantir la continuité des communications entre les différents sites ;
- assurer la disponibilité des services d'authentification et des applications métiers ;
- assurer la continuité de la plateforme e-commerce et des échanges associés avec le système d'information interne ;
- protéger les données personnelles conformément au RGPD ;
- respecter les objectifs de continuité fixés, à savoir un RTO de 4 heures et un RPO de 12 heures.

Conclusion

Le périmètre du PCA couvre les activités, ressources et dépendances nécessaires au maintien des activités essentielles de BioMarket. Il intègre notamment les activités commerciales en magasin et en ligne, les systèmes d'information, les données critiques, les infrastructures techniques ainsi que les services externalisés nécessaires à la continuité.

La plateforme e-commerce est ainsi considérée comme une composante du système d'information de BioMarket et comme une activité critique du PCA. La continuité du service repose notamment sur la maîtrise des dépendances vis-à-vis d'Iron4Software, dont l'infrastructure PaaS interne reste hors du périmètre de responsabilité de BioMarket.

Ces éléments constituent la base du **BIA présenté dans la partie 3**, qui permettra de préciser les impacts d'une interruption, les niveaux de criticité et les priorités de reprise.

3. Analyse d’Impact sur l’Activité (Business Impact Analysis – BIA)

3.1 Objectif

L’Analyse d’Impact sur l’Activité (Business Impact Analysis – BIA) vise à évaluer les conséquences d’une interruption des activités de BioMarket afin d’identifier les processus les plus critiques et de définir les priorités de reprise.

Cette analyse constitue un élément fondamental du Plan de Continuité d’Activité. Elle permet d’estimer les impacts opérationnels, financiers, réglementaires et réputationnels pouvant résulter d’un incident majeur, puis de déterminer les objectifs de continuité adaptés.

3.2 Critères d'évaluation

Les impacts ont été évalués selon les critères suivants :

Critère	**Description**
Opérationnel	Capacité de l'e’treprise à poursuivre ses activités.
Financier	Pertes économiques liées à l'i’terruption des services.
Juridique et réglementaire	Non-conformité aux obligations légales, notamment au RGPD.
Réputationnel	Dégradation de l'i’age de BioMarket auprès des clients et partenaires.

Chaque activité est ensuite classée selon son niveau de criticité.

3.3 Analyse des activités critiques

Activité critique	**Impact opérationnel**	**Impact financier**	**Impact juridique / réglementaire**	**Impact réputationnel**	**Criticité**
Vente en magasin	Élevé	Élevé	Moyen	Élevé	Critique
Gestion de la plateforme e-commerce	Très élevé	Très élevé	Élevé	Élevé	Critique
Gestion des stocks	Élevé	Élevé	Moyen	Moyen	Élevée
Gestion des données clients	Très élevé	Élevé	Très élevé	Élevé	Critique

Activité critique	Impact opérationnel	Impact financier	Impact juridique / réglementaire	Impact réputationnel	Criticité
Commandes fournisseurs	Élevé	Élevé	Faible	Moyen	Élevée
Communications internes	Moyen	Moyen	Faible	Moyen	Modérée

Les activités classées critiques devront être rétablies en priorité afin de limiter les conséquences d'un incident.

3.4 Ressources indispensables

Le maintien des activités critiques dépend des ressources suivantes :

Ressource	Activités concernées
Active Directory	Authentification des utilisateurs
Serveurs applicatifs	Gestion des ventes et des stocks
Réseau informatique	Communications entre le siège et les magasins
Plateforme e-commerce	Vente en ligne et gestion des services associés
Mécanismes de sauvegarde et de restauration	Restauration des données et reprise des services
Personnel DSI	Administration et reprise des services
Prestataires critiques	Assistance technique et maintenance

3.5 Priorités de continuité

À partir des résultats de la BIA, les priorités suivantes ont été définies :

Priorité	Activité	Objectif
1	Vente en magasin	Maintien de l'activité commerciale

Priorité	Activité	Objectif
2	Gestion de la plateforme e-commerce	Maintien des ventes en ligne
3	Gestion des stocks	Assurer la disponibilité des produits
4	Données clients	Préserver la confidentialité et la disponibilité des informations
5	Commandes fournisseurs	Garantir la continuité des approvisionnements
6	Communications internes	Coordonner efficacement la gestion de crise

Ces priorités orientent les mesures de continuité présentées dans la stratégie du PCA.

3.6 Objectifs de reprise

Conformément aux exigences définies dans le projet, les objectifs suivants sont retenus :

Indicateur	Valeur
RTO (Recovery Time Objective)	4 heures
RPO (Recovery Point Objective)	12 heures

Le RTO correspond au délai maximal admissible pour rétablir une activité critique après un incident.

Le RPO représente la perte maximale de données acceptable après un incident.

Ces objectifs constituent les cibles de reprise retenues pour les activités critiques de BioMarket. Ils guideront la définition des mesures et procédures de continuité présentées dans les parties suivantes du PCA.

Conclusion

L'Analyse d'Impact sur l'Activité a permis d'identifier les activités dont l'interruption aurait les conséquences les plus importantes pour BioMarket. Les activités de vente en magasin et en ligne, la gestion des stocks et la gestion des données clients constituent les principales priorités de continuité.

La BIA a également permis d'identifier les ressources et dépendances nécessaires à la reprise des activités et de définir les objectifs de continuité retenus, notamment un RTO de 4 heures et un RPO de 12 heures.

Ces résultats constituent la base de la stratégie de continuité et des procédures opérationnelles présentées dans la partie suivante du PCA.

4. Organisation de la gestion de crise

4.1 Objectif

L'organisation de gestion de crise a pour objectif de permettre une réaction rapide, coordonnée et efficace face à tout événement susceptible d'interrompre les activités critiques de BioMarket.

Elle définit les responsabilités des différents acteurs, les modalités de déclenchement du Plan de Continuité d'Activité (PCA) ainsi que les circuits de communication nécessaires à la gestion de la crise.

4.2 Déclenchement du PCA

Le PCA est activé lorsqu'un incident majeur compromet ou risque de compromettre la continuité des activités essentielles de BioMarket.

Le déclenchement peut intervenir notamment dans les situations suivantes :

- cyberattaque de type rançongiciel ;
- compromission de données sensibles ;
- indisponibilité prolongée des serveurs ou du réseau ;
- panne généralisée du système d'information ;
- sinistre affectant les locaux (incendie, inondation, coupure électrique majeure) ;
- indisponibilité d'un prestataire critique impactant les activités de BioMarket.

La décision d'activation est prise par la Direction Générale, sur proposition de la DSI.

4.3 Cellule de crise

En cas d'activation du PCA, une cellule de crise est constituée afin de coordonner les actions de continuité.

Fonction	**Responsabilités**
Direction Générale	Décision d'activation du PCA, arbitrage stratégique, communication institutionnelle.
DSI	Analyse et évaluation des impacts techniques, coordination des actions de sécurité, maintien ou rétablissement des services informatiques.
DPO	**Conseil sur les incidents impliquant des données personnelles et suivi des obligations RGPD associées.**
Responsables métiers	Évaluation des impacts sur les activités et définition des priorités de continuité.

Fonction	Responsabilités
Service Communication	Communication interne et externe auprès des collaborateurs, clients et partenaires.

4.4 Processus de gestion de crise

La gestion de crise suit les étapes suivantes :

1. **Détection de l'incident** : identification et qualification de l'événement.
2. **Alerte** : information immédiate de la DSI.
3. **Évaluation** : analyse des impacts techniques, métiers et, le cas échéant, des impacts sur les données personnelles.
4. **Décision** : activation du PCA par la Direction Générale si les critères sont réunis.
5. **Mise en œuvre** : application des procédures de continuité prévues par le PCA.
6. **Suivi** : pilotage des actions, communication régulière et adaptation des mesures.
7. **Clôture** : retour progressif à un fonctionnement normal et réalisation d'un retour d'expérience (RETEX).

4.5 Moyens de communication

La communication de crise vise à assurer une diffusion rapide, cohérente et maîtrisée des informations nécessaires aux différentes parties prenantes pendant un incident majeur.

Les communications sont adaptées selon la nature de l'incident et les destinataires concernés :

- collaborateurs et responsables métiers ;
- Direction Générale ;
- clients et partenaires ;
- prestataires critiques ;
- autorités compétentes lorsque cela est nécessaire, notamment en cas d'incident impliquant des données personnelles.

La Direction Générale assure la communication institutionnelle. La DSI fournit les informations techniques nécessaires à la gestion de l'incident. Le DPO est consulté lorsque l'incident implique des données personnelles afin d'évaluer les obligations de protection des données et les éventuelles notifications réglementaires.

Les communications réalisées pendant la crise sont tracées dans le journal de crise afin de garantir la traçabilité des décisions et des actions.

4.6 Escalade des incidents

L'escalade permet de transmettre rapidement les informations relatives à un incident aux personnes disposant des responsabilités nécessaires pour évaluer la situation et prendre les décisions adaptées.

Le circuit d'escalade est organisé selon le principe suivant :

Utilisateur → Support informatique → DSI → Direction Générale → Cellule de crise

Selon la nature de l'incident, la cellule de crise associe les responsables concernés, notamment les responsables métiers, le DPO, le service Communication et les prestataires critiques.

Le niveau d'escalade est adapté à la gravité et à l'impact de l'incident. Les incidents susceptibles d'affecter la continuité des activités critiques ou les données personnelles font l'objet d'une escalade renforcée.

4.7 Retour d'expérience (RETEX)

À l'issue de chaque incident majeur ou exercice de continuité, un retour d'expérience (RETEX) est réalisé afin :

- d'analyser le déroulement de l'événement ;
- d'évaluer l'efficacité des mesures et procédures mises en œuvre ;
- d'identifier les difficultés et les écarts constatés ;
- de définir les axes d'amélioration et les actions correctives nécessaires ;
- de mettre à jour les procédures du PCA si nécessaire.

Les conclusions du RETEX sont documentées et alimentent la démarche d'amélioration continue du PCA et du SMSI.

Le contenu détaillé du RETEX et les éléments à consigner sont présentés dans les annexes opérationnelles du PCA.

Conclusion

L'organisation de la gestion de crise permet à BioMarket de disposer d'une structure claire de gouvernance en cas d'incident majeur. La définition des rôles, des responsabilités, des procédures de déclenchement, des moyens de communication et des modalités d'escalade

favorise une prise de décision rapide et coordonnée, limitant ainsi les impacts sur les activités essentielles de l'entreprise.

Les retours d'expérience permettent par ailleurs d'améliorer progressivement le dispositif et d'adapter le PCA aux évolutions de l'organisation et du système d'information.

5. Stratégie de continuité et procédures opérationnelles

5.1 Objectif

La stratégie de continuité définit les dispositions organisationnelles et techniques permettant de maintenir les activités essentielles de BioMarket ou de les rétablir dans les délais fixés en cas d'incident majeur.

Elle s'appuie sur les résultats de l'analyse d'impact sur l'activité (BIA), de l'analyse des risques EBIOS RM et des objectifs de continuité fixés par l'entreprise.

Les procédures décrites ci-après précisent les actions à mettre en œuvre selon les principaux scénarios d'incident susceptibles d'affecter BioMarket.

5.2 Stratégie générale

Afin de garantir la continuité de ses activités, BioMarket prévoit les mesures suivantes :

- mise en place de sauvegardes régulières et externalisées, associées à des tests de restauration ;
- redondance des équipements critiques lorsque cela est possible ;
- authentification multifacteur pour les comptes sensibles ;
- segmentation du réseau afin de limiter la propagation d'une attaque ;
- supervision des infrastructures informatiques ;
- procédures documentées de continuité ;
- coordination avec les prestataires critiques, notamment pour les services externalisés ;
- définition et suivi des engagements de continuité associés à la plateforme e-commerce.

5.3 Procédure n°1 – Cyberattaque par rançongiciel

Objectif

Limiter la propagation du logiciel malveillant et maintenir les activités essentielles.

Actions à réaliser

Étape	Responsable
Isoler immédiatement les équipements compromis	DSI

Étape	Responsable
Informer la Direction Générale	DSI
Activer la cellule de crise si nécessaire	Direction Générale
Vérifier l'intégrité des sauvegardes	Administrateur systèmes
Restaurer les systèmes à partir des sauvegardes validées	DSI
Contrôler le retour à la normale	DSI

Objectif de reprise : RTO ≤ 4 heures.

5.4 Procédure n°2 – Panne d'un serveur critique

Objectif

Rétablir rapidement les services essentiels.

Actions

- Identifier l'origine de la panne.
- Basculer vers les équipements disponibles si possible.
- Restaurer le serveur à partir des sauvegardes.
- Vérifier le fonctionnement des applications métiers.
- Informer les responsables métiers de la reprise.

Responsable : DSI.

5.5 Procédure n°3 – Indisponibilité du réseau

Objectif

Maintenir les communications entre le siège et les magasins.

Actions

- Identifier la cause de l'incident.
- Vérifier les équipements réseau.
- Contacter le fournisseur d'accès si nécessaire.
- Utiliser les moyens de communication alternatifs.
- Informer les utilisateurs de la situation.

Responsable : Administrateur réseau.

5.6 Procédure n°4 – Perte de données

Objectif

Garantir la disponibilité et l'intégrité des informations.

Actions

- Identifier les données concernées.
- Identifier le dernier point de restauration disponible.
- Restaurer les données.
- Contrôler leur intégrité.
- Documenter l'incident.

Responsable : Administrateur systèmes.

5.7 Procédure n°5 – Sinistre sur un site

Objectif

Assurer la continuité des activités malgré l'indisponibilité des locaux.

Actions

- Sécuriser les personnes.
- Informer les services de secours si nécessaire.
- Déclencher le PCA.
- Organiser le transfert des activités vers les autres sites.
- Prioriser les activités critiques.

Responsable : Direction Générale.

5.8 Procédure n°6 – Indisponibilité d'un prestataire critique

Objectif

Limiter l'impact d'une défaillance d'un fournisseur ou prestataire essentiel.

Actions

- Identifier les services et activités impactés.
- Informer la DSI et la Direction Générale.

- Contacter le prestataire concerné.
- Appliquer les clauses contractuelles et engagements de continuité prévus.
- Mettre en œuvre les solutions de contournement disponibles.
- Informer les responsables métiers concernés.
- Assurer le suivi jusqu'au rétablissement du service.

Responsable : DSI.

5.9 Synthèse des procédures

Scénario	Responsable principal	Priorité	Objectif
Cyberattaque	DSI	Très élevée	Limiter la propagation et restaurer les systèmes
Panne serveur	DSI	Très élevée	Rétablir les applications critiques
Coupure réseau	Administrateur réseau	Élevée	Maintenir les communications
Perte de données	Administrateur systèmes	Très élevée	Restaurer les informations
Sinistre sur un site	Direction Générale	Critique	Maintenir les activités essentielles
Défaillance prestataire	DSI	Élevée	Garantir la continuité des services dépendants, notamment la plateforme e-commerce

---

5.10 Respect des objectifs de continuité

L'ensemble des procédures décrites vise à atteindre les objectifs suivants :

Indicateur	Objectif
RTO	4 heures maximum
RPO	12 heures maximum

Le respect de ces objectifs repose sur la disponibilité des mécanismes de sauvegarde et de restauration, la coordination des équipes, l'application des procédures documentées et les exercices réguliers de simulation.

Conclusion

La stratégie de continuité de BioMarket repose sur des mesures organisationnelles, humaines et techniques permettant de répondre aux principaux scénarios d'incident identifiés lors de l'analyse des risques.

Les procédures opérationnelles définissent les actions à engager, les responsabilités et les priorités afin de limiter les interruptions de service et de garantir la continuité des activités critiques.

La mise en œuvre de ces mesures doit permettre à BioMarket d'atteindre les objectifs de continuité définis dans le PCA, notamment un RTO de 4 heures et un RPO de 12 heures.

6. Tests, maintenance et amélioration du PCA

6.1 Objectif

Le Plan de Continuité d'Activité (PCA) doit être régulièrement testé, évalué et mis à jour afin de garantir son efficacité face à l'évolution des risques, des technologies et de l'organisation de BioMarket.

Les tests permettent de vérifier que les procédures définies sont applicables, que les équipes connaissent leurs responsabilités et que les objectifs de continuité peuvent être atteints dans les délais prévus.

6.2 Programme de tests

BioMarket met en place un programme annuel de tests permettant de valider les différentes composantes du PCA.

Type de test	Objectif	Fréquence	Responsable	Résultat attendu
Relecture documentaire	Vérifier l'actualité des procédures et des contacts	Annuelle	DSI	PCA, procédures et contacts à jour
Exercice de gestion de crise	Tester l'organisation de la cellule de crise	Annuelle	Direction Générale / DSI	Cellule activée et coordination conforme aux procédures
Test de restauration des sauvegardes	Vérifier l'intégrité et la disponibilité des sauvegardes	Semestrielle	DSI	Données restaurées et intégrité vérifiée
Simulation de cyberattaque	Évaluer la réaction des équipes face à un incident de sécurité	Annuelle	DSI	Procédure appliquée et escalade réalisée conformément au PCA
Test de continuité des services	Vérifier le respect des objectifs de continuité	Annuelle	DSI	RTO ≤ 4 h et RPO ≤ 12 h

---

6.3 Déroulement des tests

Chaque exercice suit les étapes suivantes :

1. Préparation du scénario et des objectifs du test.
2. Information des participants concernés.
3. Réalisation du test dans un environnement maîtrisé.
4. Observation des actions réalisées et des délais de réaction.
5. Analyse des résultats obtenus.
6. Rédaction d'un rapport de test.
7. Mise en œuvre d'actions correctives si nécessaire.

Cette démarche permet d'améliorer progressivement l'efficacité du PCA.

6.4 Critères d'évaluation

Les tests sont évalués selon plusieurs critères :

- respect des procédures définies ;
- temps de réaction des équipes ;
- atteinte des objectifs de **RTO (4 heures)** et **RPO (12 heures)** ;
- efficacité de la communication de crise ;
- disponibilité des ressources nécessaires ;
- qualité de la coordination entre les différents acteurs.

Les écarts observés sont consignés dans un rapport et font l'objet d'un plan d'amélioration.

6.5 Mise à jour du PCA

Le Plan de Continuité d'Activité est révisé dans les situations suivantes :

- évolution de l'organisation de BioMarket ;
- modification de l'architecture du système d'information ;
- évolution ou modification des services critiques, notamment de la plateforme e-commerce ;
- évolution des exigences réglementaires ;
- résultats des audits internes ;
- retour d'expérience à la suite d'un incident réel ou d'un exercice ;
- évolution des dépendances vis-à-vis des prestataires critiques.

Toute modification du PCA est validée par la Direction Générale avant sa diffusion.

6.6 Amélioration continue

Le PCA s'inscrit dans une démarche d'amélioration continue conformément aux principes du SMSI.

Les résultats des tests, des exercices de gestion de crise, des incidents réels, des audits et des retours d'expérience sont analysés afin d'identifier les éventuels écarts et les actions d'amélioration nécessaires.

Les actions correctives sont suivies jusqu'à leur réalisation et peuvent conduire à la modification des procédures, des responsabilités, des moyens techniques ou des objectifs de continuité.

Le PCA est ainsi maintenu à jour afin de rester adapté aux besoins de BioMarket, aux évolutions de son système d'information et aux nouvelles menaces susceptibles d'affecter ses activités critiques.

6.7 Conclusion

Les tests et exercices réguliers permettent de vérifier l'efficacité du Plan de Continuité d'Activité et la capacité de BioMarket à réagir face à un incident majeur.

La revue documentaire, les exercices de gestion de crise, les tests de restauration, les simulations de cyberattaque et les tests de continuité permettent d'identifier les écarts et de vérifier l'atteinte des objectifs de continuité.

Les résultats obtenus alimentent la démarche d'amélioration continue du PCA et du SMSI. Le plan est ainsi régulièrement mis à jour afin de rester adapté aux évolutions de l'organisation, du système d'information, des services critiques et des risques auxquels BioMarket est exposée.

7. Annexes opérationnelles

7.1 Contacts d'urgence

La cellule de crise doit pouvoir joindre rapidement les personnes clés en cas d'incident majeur.

Fonction	Responsable	Téléphone	E-mail
Direction Générale	À compléter	XX XX XX XX XX	direction@biomarket.fr
DSI	À compléter	XX XX XX XX XX	dsi@biomarket.fr
DPO	À compléter	XX XX XX XX XX	dpo@biomarket.fr
Responsable Réseau	À compléter	XX XX XX XX XX	reseau@biomarket.fr
Support Iron4Software	Support technique	XX XX XX XX XX	support@iron4software.fr

---

7.2 Arbre d'escalade

En cas d'incident majeur, les informations doivent être transmises selon l'ordre suivant :

Utilisateur
↓
Support informatique
↓
DSI / Equipe informatique
↓
Évaluation de la gravité et des impacts
↓
Direction Générale
↓
Cellule de crise
↙ ↓ ↘
Métiers — DPO si données personnelles concernées — Prestataires critiques
↓
Communication

Cette organisation garantit une remontée rapide des informations et facilite la prise de décision.

7.3 Check-list de déclenchement du PCA

Avant d'activer le PCA, les points suivants doivent être vérifiés :

Identification et évaluation

☐ Incident confirmé
☐ Gravité de l'incident évaluée
☐ Activités critiques impactées identifiées
☐ Ressources critiques impactées identifiées
☐ Données personnelles potentiellement concernées identifiées

Alerte et décision

☐ DSI informée
☐ Direction Générale informée
☐ DPO informé si des données personnelles sont concernées
☐ Décision d'activation du PCA prise
☐ Cellule de crise réunie

Mise en œuvre

☐ Procédure opérationnelle correspondante identifiée
☐ Responsables désignés
☐ Communication interne lancée si nécessaire
☐ Prestataire critique contacté si nécessaire
☐ Journal de crise ouvert

7.4 Journal de crise

Chaque incident doit être documenté.

Date / Heure	Événement / information	Responsable	Action réalisée	Décision / validation	Prochaine action

Le journal de crise permet d'assurer la traçabilité des événements, des actions et des décisions prises pendant la gestion de l'incident. Il constitue également un élément essentiel pour la réalisation du retour d'expérience (RETEX).

7.5 Fiche réflexe – Cyberattaque

En cas de suspicion de cyberattaque :

1. Isoler immédiatement le poste ou le serveur concerné, lorsque cela est possible sans compromettre la préservation des preuves.

2. Informer immédiatement la DSI.
3. Ne pas redémarrer, modifier ou réinitialiser l'équipement sans autorisation.
4. Préserver les éléments utiles à l'analyse de l'incident (journaux, alertes, captures et informations disponibles).
5. Évaluer le périmètre et l'impact sur les activités critiques.
6. Déterminer si des données personnelles sont susceptibles d'être concernées et informer le DPO le cas échéant.
7. Déclencher le PCA si les critères d'activation sont atteints.
8. Informer la Direction Générale.
9. Restaurer les services conformément aux procédures validées, après sécurisation de la situation.

7.6 Fiche réflexe – Panne serveur

En cas d'indisponibilité d'un serveur critique :

1. Identifier le serveur concerné.
2. Vérifier l'origine et l'étendue de la panne.
3. Informer la DSI.
4. Activer les procédures de continuité applicables.
5. Restaurer les données à partir du dernier point de restauration disponible, si nécessaire.
6. Vérifier le bon fonctionnement et l'intégrité des applications.
7. Informer les utilisateurs du rétablissement.

7.7 Fiche réflexe – Perte de connexion réseau

En cas de coupure réseau :

1. Identifier le périmètre concerné.
2. Vérifier les équipements réseau et les connexions.
3. Informer la DSI.
4. Contacter le fournisseur d'accès si nécessaire.
5. Basculer vers les moyens de communication alternatifs disponibles.
6. Informer les responsables métiers concernés.
7. Suivre le rétablissement du service et documenter l'incident.

7.8 Retour d'expérience (RETEX)

Après chaque incident ou exercice, un retour d'expérience est réalisé.

Le rapport comprend notamment :

- Scénario rencontré
- Causes de l'incident
- Actions engagées
- Délais de réaction
- Difficultés rencontrées
- Axes d'amélioration
- Actions correctives décidées
- Responsable
- Échéance
- Statut

Les conclusions du RETEX alimentent l'amélioration continue du PCA et du SMSI.

7.9 Gestion documentaire

Le PCA est un document maîtrisé conformément aux exigences du SMSI.

Toute modification doit être :

- validée par la Direction Générale ;
- revue par la DSI;
- versionnée et datée ;
- enregistrée dans l'historique des versions ;
- diffusée uniquement aux personnes autorisées.

Une révision du PCA est effectuée au minimum une fois par an ou à la suite :

- d'un incident majeur ;
- d'un exercice de simulation ;
- d'une évolution importante du système d'information ;
- d'une modification de l'organisation ;
- d'une évolution des services critiques ou des dépendances vis-à-vis des prestataires.

8. Conclusion

Le Plan de Continuité d'Activité constitue un élément essentiel du dispositif de résilience de BioMarket. Il définit les dispositions organisationnelles, humaines et techniques nécessaires pour maintenir ou rétablir les activités critiques de l'entreprise en cas d'incident majeur.

Fondé sur l'analyse des risques et l'analyse d'impact sur l'activité, le PCA permet d'identifier les activités prioritaires, les ressources indispensables et les dépendances critiques. Il définit également les responsabilités, les modalités de gestion de crise ainsi que les procédures opérationnelles à mettre en œuvre selon les principaux scénarios d'incident.

Les objectifs de continuité retenus, notamment un **RTO de 4 heures et un RPO de 12 heures**, constituent les cibles de reprise du dispositif. Leur atteinte repose sur la mise en œuvre des mesures de continuité prévues, notamment les mécanismes de sauvegarde et de restauration, la coordination des équipes et la maîtrise des dépendances vis-à-vis des prestataires critiques.

Enfin, les exercices réguliers, les tests, les retours d'expérience et la mise à jour du PCA permettent d'inscrire le dispositif dans une démarche d'amélioration continue et de maintenir son adéquation avec les évolutions du système d'information et de l'organisation de BioMarket.

Le PCA constitue ainsi un complément opérationnel de la PSSI et de l'analyse des risques, contribuant à renforcer la résilience de BioMarket et sa capacité à poursuivre ses activités essentielles face aux incidents majeurs.